التقرير الموحد للمراجعة ومتطلبات التطوير

منصة محمد بن عبد الوهاب الثانوية للبنين

الملاحظات المُتحقَّق منها على النسخة الحالية
والمتطلبات الأمنية والتشغيلية للنسخة الإنتاجية
وخطة التنفيذ الموحدة

رمز الوثيقة: MBW-REV-2026-02 · الإصدار 2.0
تاريخ الإصدار: 4 نوفمبر 2026
المرجعية: المعيار الوطني لضمان أمن المعلومات في دولة قطر (NIAS)
وقانون حماية خصوصية البيانات الشخصية رقم 13 لسنة 2016

تصنيف: داخلي — للاستخدام المدرسي

1. الملخص التنفيذي

هذه الوثيقة تجمع مصدرين في تقرير واحد:

1. **مراجعة مباشرة لكود المنصة المنشورة**، وهي الإصدار 1.0 من هذه الوثيقة.
2. **تقرير مراجعة مكتبية** برمز MIA-AUD-2026-01، أُعد بأداة ذكاء اصطناعي، وبُني على نموذج تشغيلي مفترض للمنصة.

بعد مقارنة التقريرين بالكود الفعلي، فُصلت الوثيقة إلى جزأين بحسب طبيعة كل بند:

13	22	3	5
ملاحظة مُتحقَّق منها على النسخة الحالية (الجزء أ)	متطلباً إلزامياً للنسخة الإنتاجية (الجزء ب)	ملاحظات عالية الخطورة تحتاج معالجة فورية	مراحل تنفيذ، من فوري إلى ما بعد الإطلاق

الخلاصة

- **المنصة اليوم نموذج أولي للواجهة فقط.** لا يوجد خادم، ولا قاعدة بيانات، ولا حسابات، ولا بيانات طلاب. لذلك لا تُعالج حالياً أي بيانات شخصية.
- **أهم خطر قائم الآن:** الصفحة على رابط عام، وتحمل شعار الوزارة واسم المدرسة، وفيها نموذج كلمة مرور. يجب معالجة ذلك خلال أسبوع (A-S1).
- **أهم خطر في التصميم:** المستخدم يختار دوره بنفسه من الرابط، وتقييد السجلات الحساسة نص للعرض فقط. يجب تصحيح ذلك قبل بناء الخادم (A-S2 وA-S3).
- **ملاحظات التقرير المكتبي (F-01 إلى F-16)** لا تنطبق على النسخة الحالية كثغرات، لأنها تصف مكونات غير موجودة. لكنها أُعيد تصنيفها إلى **متطلبات إلزامية** للنسخة الإنتاجية، وأُضيفت إليها متطلبات خاصة بطبيعة المنصة (الجزء ب).
- **حُذفت درجات النضج والامتثال الرقمية** الواردة في التقرير المكتبي (مثل 2.4 من 5، و55%)، لأنها لم تُبنَ على قياس فعلي. سيُقاس خط الأساس بعد أول فحص للنسخة الإنتاجية.
- **استُبدل الإطار المرجعي** ECC-1:2018 بالمرجعية القطرية، لأن ECC-1:2018 خاص بالمملكة العربية السعودية، بينما المدرسة تتبع وزارة التربية والتعليم والتعليم العالي في دولة قطر.

> **قرار مطلوب من الإدارة:** اعتماد المرحلة 0 فوراً (الأسبوع الأول)، وتسمية مالك للمنصة ومسؤول أمن لها قبل بدء بناء الخادم.

2. النطاق والمنهجية والمصادر

البند	الوصف
النظام محل المراجعة	النسخة التجريبية المنشورة من المنصة على رابط Claude Artifact، كما كانت في 4 نوفمبر 2026
طريقة المراجعة	تفكيك الكود المجمّع داخل الصفحة، وقراءة منطق التطبيق كاملاً، والبحث عن أي اتصال بالشبكة أو تخزين أو جمع بيانات
ما لم يُراجَع	لا يوجد خادم ولا قاعدة بيانات ولا بنية تحتية لمراجعتها، ولم يُجرَ اختبار اختراق
المصدر 1	مراجعة الكود المباشرة (الإصدار 1.0)، وهي أساس الجزء أ
المصدر 2	التقرير المكتبي MIA-AUD-2026-01 (16 ملاحظة)، وأُعيد تصنيف ملاحظاته إلى متطلبات في الجزء ب، والتفاصيل في القسم 9
المرجعية	المعيار الوطني لضمان أمن المعلومات (NIAS) الصادر عن الوكالة الوطنية للأمن السيبراني في قطر، وقانون حماية خصوصية البيانات الشخصية رقم 13 لسنة 2016، وسياسات الوزارة الخاصة بالبيانات التعليمية

ملاحظة: ربط كل متطلب ببند محدد من بنود NIAS يتولاه مسؤول أمن المعلومات في المدرسة أو الوزارة، بالرجوع إلى أحدث إصدار معتمد من المعيار.

تصنيف الخطورة المعتمد

المستوى	المعيار	مدة المعالجة
عالية	خطر قائم الآن على السمعة أو على البيانات، أو خلل في التصميم سيتحول إلى ثغرة جسيمة إذا بُني عليه	فوري، خلال 7 إلى 30 يوماً
متوسطة	نقص يؤثر على الموثوقية أو قابلية الصيانة، أو يزيد المخاطر مستقبلاً	خلال 30 إلى 90 يوماً
منخفضة	تحسين في جودة الاستخدام أو الأداء	ضمن التطوير الاعتيادي

3. الوضع الحالي للمنصة

الرئيسية ← اختيار الهيئة (3) ← اختيار الدور (11) ← تسجيل الدخول (تجريبي)

البند	الوضع الفعلي
التقنيات	React 19.2.8 وTailwind CSS 4، والتنقل بالروابط من نوع `#/section/…` و`#/login/…`
البيانات	بيانات وهمية مكتوبة داخل الكود: 3 هيئات و11 دوراً فقط
تسجيل الدخول	النموذج لا يرسل شيئاً ولا يحفظه، ويعرض رسالة "لم يتم تسجيل أي دخول"
الشبكة والتخزين	لا يوجد اتصال بالشبكة، ولا تخزين في المتصفح، ولا ملفات تعريف ارتباط
المستخدمون المعرّفون	موظفو المدرسة فقط، في 11 دوراً. لا يوجد دور للطالب أو لولي الأمر
الاستضافة	صفحة منشورة على Claude Artifact برابط عام
الحجم	حوالي 410KB، منها حوالي 17KB منطق التطبيق، وحوالي 97KB صورة الشعار المضمّنة

الهيئة	الأدوار
الهيئة الأكاديمية	المنسق، المعلم
الهيئة الإدارية	منسق شؤون الطلاب، المشرف الإداري، الاختصاصي النفسي*، الاختصاصي الاجتماعي*، الممرض*، موظف الاستقبال
إدارة النظام	مدير المدرسة، نائب المدير للشؤون الأكاديمية، مدير النظام

* أدوار عليها شارة "سجلات مقيّدة حسب الاختصاص"

الجزء أ

الملاحظات المُتحقَّق منها على النسخة الحالية

4. الملاحظات الأمنية

A-S1 عالية — الشعار الرسمي واسم المدرسة على رابط عام فيه نموذج كلمة مرور

الوصف: الصفحة تعرض شعار وزارة التربية والتعليم والتعليم العالي واسم المدرسة، ومعهما نموذج دخول بكلمة مرور، على رابط عام.

الأثر: قد تُصنَّف الصفحة كمحاولة تصيّد أو انتحال صفة جهة رسمية، وقد يكتب فيها مستخدم بيانات دخوله الحقيقية.

المعالجة:

- جعل الرابط خاصاً.
- أخذ موافقة مكتوبة على استخدام الشعار والاسم.
- استبدال حقلي اسم المستخدم وكلمة المرور بزر "دخول تجريبي" (التعديل 7.1).

التحقق: فتح الرابط من حساب غير مصرّح له يُرفض، ولا يوجد أي حقل لكلمة مرور في النسخة التجريبية.

A-S2 عالية (في التصميم) — المستخدم يختار دوره بنفسه قبل تسجيل الدخول

الوصف: الدور يُختار من الواجهة، ويظهر في الرابط مثل `#/login/system-admin`.

الأثر: إذا بُني النظام الإنتاجي على هذا المنطق، يستطيع أي مستخدم أن يطلب صلاحيات أعلى من صلاحياته بتغيير الرابط.

المعالجة: شاشة دخول واحدة، والخادم يحدد الدور من حساب المستخدم، ولا يُعتمد على أي قيمة للدور تأتي من المتصفح (التعديل 7.2، والمتطلب R-02).

التحقق: تعديل الرابط أو الطلب لا يمنح أي صلاحية إضافية في اختبار الاختراق.

A-S3 عالية (في التصميم) — تقييد السجلات الحساسة موجود كنص للعرض فقط

الوصف: شارة "سجلات مقيّدة" على أدوار الاختصاصي النفسي والاختصاصي الاجتماعي والممرض مجرد علامة في الواجهة.

الأثر: السجلات النفسية والصحية لطلاب قاصرين من أكثر البيانات حساسية، وأي تسرب لها له أثر قانوني وأخلاقي كبير.

المعالجة: تطبيق التقييد في الخادم على مستوى السجل والحقل، وعزل هذه السجلات حتى عن مدير النظام، وتسجيل كل عملية اطلاع عليها (المتطلبان R-03 وR-12).

A-S4 متوسطة غياب تصميم معتمد للهوية والتحقق

الوصف: لم يُحدَّد بعد كيف سيسجل المستخدمون دخولهم في النسخة الإنتاجية.

المعالجة: اعتماد الدخول الموحد (SSO) عبر حساب المدرسة، والتحقق الثنائي (MFA) للأدوار الحساسة (المتطلبان R-01 و-R 04).

A-S5 متوسطة الامتثال لقانون حماية البيانات غير مُخطَّط له

الوصف: النسخة الإنتاجية ستعالج بيانات شخصية لطلاب قاصرين، منها بيانات صحية ونفسية، ولا توجد بعد خطة امتثال.

المعالجة: تقييم أثر على الخصوصية قبل البناء، وسياسة للاحتفاظ بالبيانات، ومراعاة مكان الاستضافة (المتطلبان R-21 وR-22).

A-S6 منخفضة الهيكل الإداري ظاهر للعموم قبل تسجيل الدخول

المعالجة: هذا مقبول في النسخة التجريبية، ويُفضّل إخفاء قائمة الأدوار في الإنتاج حتى يسجل المستخدم دخوله.

5. الملاحظات الفنية

A-T1 متوسطة دالة تحميل البيانات لا تعالج الأخطاء

الوصف: إذا فشل طلب البيانات تبقى الشاشة على "جارٍ التحميل..." إلى ما لا نهاية، ولا يوجد Error Boundary يلتقط أعطال الواجهة.

المعالجة: إضافة حالة خطأ مع زر لإعادة المحاولة، وإضافة Error Boundary (التعديل 7.3).

A-T2 متوسطة الكود المصدري غير موجود في مستودع Git

الأثر: لا يوجد تتبع للتغييرات، ولا مراجعة للكود، ولا نسخة احتياطية منه، ولا يمكن إعادة البناء.

المعالجة: نقل الكود إلى مستودع Git مع ملف README وخطوات البناء، وجعل مراجعة الكود إلزامية قبل الدمج (المتطلب R-17).

A-T3 منخفضة الخط الأساسي غير متوفر في أغلب الأجهزة

الوصف: خط "Sakkal Majalla" موجود في ويندوز فقط.

المعالجة: تحميل خط Noto Naskh Arabic أو Noto Kufi Arabic (التعديل 7.4).

A-T4 منخفضة صورة الشعار مضمّنة بحجم كبير

الوصف: الشعار صورة PNG حجمها حوالي 97KB داخل الملف.

المعالجة: تحويله إلى SVG أو WebP مضغوط بحجم أقل من 15KB تقريباً.

A-T5 منخفضة شريط العنوان فارغ في الرئيسية على الجوال

الوصف: الشعار مخفي في الصفحة الرئيسية، والاسم مخفي على الشاشات الصغيرة (`hidden sm:block`).

المعالجة: إظهار اسم مختصر على الجوال (التعديل 7.5).

6. الملاحظات التشغيلية

#	البند	الخطورة	الوضع والمعالجة
A-O1	الاستضافة	متوسطة	صفحات Claude Artifact مناسبة للعرض فقط، وليست مكاناً لاستضافة بيانات الطلاب. تلزم استضافة معتمدة تديرها المدرسة أو الوزارة (R-22)
A-O2	غياب مالك معتمد للمنصة	متوسطة	تسمية مالك للمنصة ومسؤول أمن لها، بصلاحيات واضحة (القسم 12)
A-O3	وضوح أنها نسخة تجريبية	متوفر ✓	الإبقاء على التنبيه في التذييل وفي شاشة الدخول

البنود التشغيلية الأخرى، مثل النسخ الاحتياطي والمراقبة والبيئات والتعافي، لا تنطبق على النسخة الحالية لأنها لا تحتوي بيانات. لذلك نُقلت كمتطلبات إلى الجزء ب.

7. تعديلات الكود المقترحة للنسخة الحالية

7.1 استبدال نموذج كلمة المرور بدخول تجريبي (A-S1)

```
// LoginPage — demo mode: no username/password fields
<div role="note" className="...">
  نسخة تجريبية للعرض فقط — لا تُدخل أي بيانات حقيقية.
</div>
<button onClick={() => navigate(`/demo/${role.id}`)} className="...">
  دخول تجريبي بصفة {role.title}
</button>
```

7.2 تحديد الدور من الخادم وليس من الرابط (A-S2 وA-S3)

```
// Client: one login entry point, role comes from the server session
const session = await api.get("/auth/me");   // { user, roles: ["teacher"], scopes: {...} }

// Server (example, Express): enforce on EVERY request
function requireRole(...allowed) {
  return (req, res, next) =>
    req.user && req.user.roles.some(r => allowed.includes(r))
      ? next() : res.status(403).end();
}
app.get("/api/counseling/:studentId",
  requireRole("psychologist", "social-worker"),
  requireCaseAssignment,            // only the specialist assigned to this case
  auditRead("counseling"),          // log every read of restricted records
  getCounselingRecord);
```

7.3 معالجة الأخطاء في تحميل البيانات (A-T1)

```
function useAsync(fn, deps) {
  const [state, setState] = useState({ data: undefined, loading: true, error: null });
  useEffect(() => {
    let alive = true;
    setState(s => ({ ...s, loading: true, error: null }));
    fn().then(
      data  => alive && setState({ data, loading: false, error: null }),
      error => alive && setState({ data: undefined, loading: false, error })
    );
    return () => { alive = false; };
  }, deps);
  return state;
}
```

7.4 تحميل الخط العربي (A-T3)

```
<link rel="stylesheet"
  href="https://fonts.googleapis.com/css2?family=Noto+Naskh+Arabic:wght@400;700&display=swap">
--font-sans: "Noto Naskh Arabic", "Sakkal Majalla", Tahoma, sans-serif;
```

7.5 اسم مختصر في الشريط على الجوال (A-T5)

```
<span className="sm:hidden text-base font-bold">منصة ابن عبد الوهاب</span>
<span className="hidden sm:block text-lg sm:text-xl font-bold">{fullName}</span>
```

الجزء ب

المتطلبات الإلزامية للنسخة الإنتاجية

هذه المتطلبات شروط قبول للنسخة الإنتاجية، ولا يُطلق النظام ببيانات حقيقية قبل تحقيق كل متطلب أولويته "إلزامي قبل الإطلاق".
عمود "المصدر" يوضح أصل كل متطلب: **A** من الجزء أ، و**F** من التقرير المكتبي، و**جديد** للمتطلبات المضافة في هذه الوثيقة.

8. سجل المتطلبات

8.1 الهوية والصلاحيات

#	المتطلب	المصدر	الأولوية	معيار القبول
R-01	دخول موحد (SSO) عبر حساب المدرسة، وعدم تخزين كلمات مرور في المنصة إن أمكن	A-S4	إلزامي	جميع المستخدمين يدخلون عبر مزود الهوية المعتمد
R-02	الخادم يحدد الدور من الحساب، والصلاحيات تُطبَّق على كل طلب	A-S2	إلزامي	اختبار تغيير الدور أو المعرّف في الطلب يعيد 403
R-03	صلاحيات حسب الإسناد (الصفوف والمواد والحالات)، وعزل السجلات النفسية والصحية	A-S3	إلزامي	مصفوفة الصلاحيات (القسم 10) مطبقة ومختبرة آلياً
R-04	التحقق الثنائي (MFA) إلزامي لمدير النظام والإدارة والأدوار المقيّدة	F-06	إلزامي	لا يمكن الدخول بهذه الأدوار دون عامل ثانٍ
R-05	منع الحسابات وكلمات المرور الافتراضية، والقفل بعد 5 محاولات فاشلة	F-06	إلزامي	فحص الحسابات قبل الإطلاق لا يجد أي حساب افتراضي
R-06	إذا وُجدت كلمات مرور محلية، تُخزَّن بخوارزمية Argon2id أو bcrypt مع Salt فريد لكل مستخدم	F-07	إلزامي	مراجعة الكود وعينة من قاعدة البيانات
R-07	إنهاء الجلسة بعد 15 دقيقة خمول للأدوار الإدارية و60 دقيقة لغيرها، وإبطال الجلسات عند تغيير الحساب	F-09	إلزامي	اختبار وظيفي لسيناريوهات الجلسة

8.2 حماية البيانات والتطبيق

#	المتطلب	المصدر	الأولوية	معيار القبول
R-08	تشفير البيانات أثناء النقل (HTTPS فقط) وأثناء التخزين، مع تشفير إضافي للحقول الحساسة	F-08	إلزامي	فحص الإعدادات، وتعذّر قراءة الحقول الحساسة مباشرة من القاعدة
R-09	تحديد معدل الطلبات على واجهات API وعلى شاشة الدخول	F-03	إلزامي	100 طلب متتالٍ من مصدر واحد تُحظر
R-10	الأسرار ومفاتيح الربط في خزنة مركزية، وليست في الكود، مع تدويرها دورياً	F-04	إلزامي	مسح الكود آلياً لا يجد أي سر مكتوب داخله

#	المتطلب	المصدر	الأولوية	معيار القبول
R-11	رسائل خطأ عامة للمستخدم، والتفاصيل تذهب إلى السجلات الداخلية فقط	F-05 · A-T1	إلزامي	فحص عيّنة من الأخطاء لا يُظهر تفاصيل تقنية
R-12	سجل نشاطات غير قابل للتعديل، يشمل كل اطلاع على سجل مقيّد	F-11 · A-S3	إلزامي	كل قراءة لسجل نفسي أو صحي تظهر في السجل مع المستخدم والوقت
R-13	فحص شهري للثغرات، وجرد لمكتبات الطرف الثالث، ومعالجة الثغرات الحرجة خلال 7 أيام	F-10	إلزامي	تقرير فحص شهري وسجل الثغرات
R-14	إعدادات أمان المتصفح: سياسة أمان المحتوى (CSP)، وملفات تعريف ارتباط آمنة، وحماية من CSRF	جديد	إلزامي	فحص ترويسات الاستجابة

8.3 التشغيل والاستمرارية

#	المتطلب	المصدر	الأولوية	معيار القبول
R-15	نسخ احتياطي يومي مشفر وفق قاعدة 3-2-1، واختبار استعادة كل ربع سنة	F-12	إلزامي	محضر اختبار استعادة ناجح قبل الإطلاق
R-16	خطة تعافٍ معتمدة: مدة تعافٍ مقبولة (RTO) 8 ساعات، وحد فقد بيانات مقبول (RPO) 24 ساعة كبداية	F-13	إلزامي	خطة معتمدة، وتمرين أول موثق
R-17	Git، ومراجعة كود إلزامية، ومسار نشر آلي	A-T2 · F-01	إلزامي	كل إصدار له سجل في المستودع ومسار النشر
R-18	بيئات منفصلة للتطوير والاختبار والإنتاج، وبيانات وهمية فقط خارج الإنتاج	F-01	إلزامي	كل تغيير يمر ببيئة الاختبار قبل الإنتاج
R-19	مراقبة توفر الخدمة والأداء، وتنبيهات آلية، وهدف توفر 99.5%	F-15	إلزامي	لوحة مؤشرات حية وتقرير توفر شهري
R-20	إجراء موثق لإدارة التغيير، واتفاقية مستوى خدمة داخلية، وقناة دعم واحدة، وحزمة توثيق محدّثة	F-02 · F-14 · F-16	مُستحسن	الوثائق معتمدة ولها تاريخ مراجعة

8.4 الامتثال والحوكمة

#	المتطلب	المصدر	الأولوية	معيار القبول
R-21	تقييم أثر على الخصوصية، وسياسة للاحتفاظ بالبيانات وحذفها، وإشعار خصوصية لأولياء الأمور، وفق القانون 13/2016	A-S5 · جديد	إلزامي	التقييم معتمد من مسؤول حماية البيانات
R-22	استضافة معتمدة وفق سياسات الوزارة لمكان البيانات وتصنيفها، واختبار اختراق مستقل قبل الإطلاق	A-O1 · جديد	إلزامي	تقرير اختبار الاختراق بلا ثغرات حرجة أو عالية مفتوحة

9. مطابقة ملاحظات التقرير المكتبي (MIA-AUD-2026-01)

يوضح الجدول ما حدث لكل ملاحظة من ملاحظات التقرير المكتبي، حتى يمكن تتبعها دون فقد أي بند.

الرمز	الملاحظة في التقرير المكتبي	الوضع على النسخة الحالية	القرار
F-01	غياب بيئة اختبار منفصلة	لا ينطبق (لا يوجد إنتاج)	متطلب R-17 وR-18
F-02	توثيق غير محدّث	ينطبق جزئياً	متطلب R-20، ويُدمج مع A-T2
F-03	واجهات API دون تحديد معدل الطلبات	لا ينطبق (لا توجد واجهات)	متطلب R-09
F-04	بيانات اعتماد مكتوبة في ملفات الإعدادات	لا ينطبق (تم التحقق من الكود)	متطلب R-10
F-05	رسائل خطأ تفصيلية	لا ينطبق	متطلب R-11
F-06	حسابات إدارية بكلمات مرور افتراضية ودون MFA	لا ينطبق (لا توجد حسابات)	متطلبان R-04 وR-05
F-07	كلمات مرور بتجزئة قديمة دون Salt	لا ينطبق (لا تُخزَّن كلمات مرور)	متطلب R-06
F-08	بيانات الطلبة غير مشفرة	لا ينطبق (لا توجد بيانات طلاب)	متطلب R-08
F-09	إدارة الجلسات	لا ينطبق	متطلب R-07
F-10	غياب إدارة الثغرات	ينطبق جزئياً (مكتبات الواجهة)	متطلب R-13
F-11	سجلات أمنية محلية	لا ينطبق	متطلب R-12، موسَّع ليشمل الاطلاع على السجلات
F-12	نسخ احتياطي غير مختبر	لا ينطبق (لا توجد بيانات)	متطلب R-15
F-13	غياب خطة الاستمرارية والتعافي	لا ينطبق	متطلب R-16
F-14	غياب اتفاقية مستوى الخدمة	لا ينطبق	متطلب R-20
F-15	مراقبة ردّ الفعل	لا ينطبق	متطلب R-19
F-16	إدارة التغيير غير موثقة	ينطبق جزئياً	متطلبان R-17 وR-20

بنود أخرى من التقرير المكتبي

البند	القرار والسبب
الإطار المرجعي ECC-1:2018	استُبدل بالمرجعية القطرية (NIAS والقانون 13/2016)، لأن ECC-1:2018 إطار سعودي لا يُلزم مدرسة قطرية
درجات الامتثال والنضج (55%، 2.4 من 5، والمستهدف 3.6)	حُذفت، لأنها لم تُبنَ على فحص فعلي. يُقاس خط الأساس بعد أول فحص للنسخة الإنتاجية

البند	القرار والسبب
وصف المستخدمين (طلبة وأولياء أمور)	صُحّح: المنصة الحالية لموظفي المدرسة فقط (11 دوراً)
وصف الاستضافة (بنية تحتية داخلية)	صُحّح: الاستضافة الحالية صفحة Claude Artifact
الرأي الفني "قابلة للتشغيل الآمن"	استُبدل بالرأي الوارد في القسم 12
تسمية مالك أمن، ودورة تدقيق سنوية، وربط المؤشرات بالقرارات	اعتُمدت كما هي في القسم 12

10. مصفوفة الصلاحيات المقترحة

الرموز: ق = قراءة، ت = تعديل، — = لا صلاحية. "مسند" تعني الصفوف أو المواد أو الحالات المسندة للمستخدم فقط. تحتاج المصفوفة إلى اعتماد إدارة المدرسة قبل التطوير.

الدور	الدرجات	الغياب والتأخر	السلوك	السجل النفسي والاجتماعي	السجل الصحي	الحسابات
المعلم	ق/ت (مسند)	ق/ت (مسند)	ت (مسند)	—	—	—
المنسق	ق (المادة)	ق (المادة)	ق	—	—	—
منسق شؤون الطلاب	ق	ق/ت	ق/ت	إحالة فقط	—	—
المشرف الإداري	—	ق/ت (الشعب)	ق/ت	إحالة فقط	—	—
الاختصاصي النفسي	ق	ق	ق	ق/ت (حالاته)	—	—
الاختصاصي الاجتماعي	ق	ق	ق	ق/ت (حالاته)	—	—
الممرض	—	ق	—	—	ق/ت	—
موظف الاستقبال	—	تسجيل الخروج	—	—	—	—
مدير المدرسة	ق	ق	ق	ملخص فقط	ملخص فقط	—
نائب المدير الأكاديمي	ق/اعتماد	ق	ق	—	—	—
مدير النظام	—	—	—	—	—	ق/ت + سجل النشاطات

مبادئ المصفوفة:

- أقل صلاحية لازمة لكل دور.
- مدير النظام يدير الحسابات ولا يطّلع على بيانات الطلاب.
- السجلات النفسية والصحية لا يراها إلا صاحب الاختصاص المسند للحالة.
- كل اطلاع على سجل مقيّد يُسجَّل (R-12).

11. خطة التنفيذ الموحدة

المرحلة 0

فوري، الأسبوع الأول

- A-S1: جعل الرابط خاصاً، وأخذ الموافقة على الشعار، واستبدال حقل كلمة المرور بزر دخول تجريبي.
- تسمية مالك للمنصة ومسؤول أمن لها (A-O2).

المسؤول: إدارة المدرسة وفريق التطوير. مؤشر الإنجاز: الرابط خاص، ولا يوجد حقل كلمة مرور.

المرحلة 1
أسبوعان إلى 3

- نقل الكود إلى Git (A-T2 وR-17).
- إصلاح الملاحظات A-T1 وA-T3 وA-T4 وA-T5.
- اعتماد مصفوفة الصلاحيات (القسم 10).
- تقييم الأثر على الخصوصية (R-21).
- اختيار الاستضافة ومزود الهوية.

المسؤول: فريق التطوير، ومسؤول حماية البيانات.

المرحلة 2
6 إلى 10 أسابيع

- بناء الخادم وقاعدة البيانات، مع تطبيق متطلبات الهوية والصلاحيات (R-01 إلى R-07) ومتطلبات حماية البيانات والتطبيق (R-08 إلى R-14) من البداية.
- البيئات المنفصلة (R-18) ومسار النشر (R-17).

المسؤول: فريق التطوير. مؤشر الإنجاز: اختبارات آلية للصلاحيات ناجحة.

المرحلة 3
قبل الإطلاق

- النسخ الاحتياطي واختبار الاستعادة (R-15).
- خطة التعافي (R-16).
- المراقبة (R-19).
- اختبار اختراق مستقل (R-22).
- تجربة محدودة مع عينة من المستخدمين ببيانات حقيقية مصرّح بها.

بوابة الإطلاق: كل متطلب "إلزامي" محقق، ولا ثغرات حرجة أو عالية مفتوحة.

المرحلة 4
بعد الإطلاق

- تقرير متابعة شهري.
- فحص ثغرات شهري (R-13).
- اختبار استعادة كل ربع سنة.
- تدقيق سنوي يقيس خط الأساس الفعلي للامتثال.
- استكمال المتطلب R-20.

12. الرأي الفني والتوصيات الحاكمة

الرأي الفني:

- النسخة الحالية **نموذج أولي للواجهة، وهو مقبول كأداة عرض**، بشرط تنفيذ المرحلة 0. ولا يحمل حالياً أي خطر على بيانات الطلاب لأنه لا يعالج أي بيانات.
- النسخة الحالية **غير صالحة للتشغيل الفعلي**، ولا يجوز إدخال بيانات حقيقية فيها.
- لا تُطلق النسخة الإنتاجية إلا بعد تحقيق جميع المتطلبات الإلزامية (الجزء ب) واجتياز اختبار اختراق مستقل.

التوصيات الحاكمة

1. **تسمية مالك للمنصة ومسؤول أمن لها**، بتفويض يشمل الموافقة على التغييرات الحساسة، والإبلاغ الشهري للإدارة.

2. **اعتماد مصفوفة الصلاحيات من إدارة المدرسة** قبل كتابة أي كود للخادم، لأنها أساس المتطلبات R-02 وR-03 وR-12.
3. **اعتماد بوابة إطلاق**: لا تدخل أي بيانات حقيقية قبل تحقيق المتطلبات الإلزامية.
4. **اعتماد دورة تدقيق سنوية** تشمل فحصاً فعلياً للنظام، وليس مراجعة مكتبية فقط.
5. **اعتماد أي تقرير تدقيق** بعد التأكد من أنه يصف النظام الفعلي ومن مصدره، خاصة التقارير المُعدّة بأدوات الذكاء الاصطناعي.

مصطلحات

المصطلح	الشرح
NIAS	المعيار الوطني لضمان أمن المعلومات في دولة قطر
SSO / MFA	الدخول الموحد بحساب واحد / التحقق بعامل ثانٍ إضافة إلى كلمة المرور
Argon2id / bcrypt / Salt	خوارزميات حديثة لتخزين كلمات المرور / قيمة عشوائية فريدة تُضاف قبل التجزئة
CSP / CSRF	سياسة أمان المحتوى في المتصفح / هجوم تزوير الطلبات عبر المواقع
RTO / RPO	أقصى مدة مقبولة لعودة الخدمة بعد عطل / أقصى فقد بيانات مقبول مقاساً بالزمن
3-2-1	ثلاث نسخ من البيانات، على وسيطين مختلفين، منها نسخة خارج الموقع

13. سجل الإصدارات والاعتماد

الإصدار	التاريخ	الوصف
1.0	4 نوفمبر 2026	مراجعة مباشرة لكود النسخة التجريبية: الملاحظات واقتراحات التعديل
—	نوفمبر 2026	تقرير مراجعة مكتبية MIA-AUD-2026-01، أُعد بأداة ذكاء اصطناعي، وروجع في هذه الوثيقة
2.0	4 نوفمبر 2026	النسخة الموحدة: فصل الملاحظات المُتحقَّق منها عن المتطلبات، ومطابقة كاملة للتقرير المكتبي، واعتماد المرجعية القطرية

أعدّ بواسطة	راجعه (مالك أمن المنصة)	اعتمده (إدارة المدرسة)
الاسم والصفة	الاسم والصفة	الاسم والصفة
التاريخ والتوقيع	التاريخ والتوقيع	التاريخ والتوقيع

حدود الوثيقة: الجزء أ مبني على فحص الكود المنشور في تاريخ الإصدار. الجزء ب متطلبات تصميم وليس نتائج فحص. المدد الزمنية تقديرية وتعتمد على حجم الفريق. أُعدّت هذه الوثيقة بمساعدة أداة ذكاء اصطناعي (Claude)، وتحتاج إلى مراجعة واعتماد بشري قبل الاستخدام الرسمي.